

Panduan praktik

5 simulasi serangan

Database Security in Practice
Dendi Zuckergates | Panduan khusus Invoice Lab lokal

Gunakan panduan ini sambil membuka browser dan PowerShell. Setiap skenario menjelaskan **apa yang dicoba, cara menjalankan, hasil yang diharapkan, dan bukti yang diperiksa**.

Mulai dari sini

1. Ekstrak seluruh paket kegiatan jika masih berupa ZIP. Pastikan Docker Desktop terpasang dan memakai **Linux containers**. Build pertama membutuhkan internet.
2. Di folder utama kegiatan, klik dua kali **JALANKAN-LAB.cmd**. Tunggu pesan **Lab siap**. Launcher menyalakan Docker Desktop bila perlu, menyiapkan lab, lalu membuka tiga halaman demo.
3. Untuk perintah di PDF ini, buka folder **lab** di File Explorer, klik address bar, ketik **powershell**, lalu Enter. Pastikan folder tersebut berisi **lab.ps1** dan **compose.yaml**.

Alternatif: mulai lewat PowerShell

```
.\lab.ps1 Start
```

Tunggu perintah selesai dan halaman login dapat dibuka. Kalau lab sudah dinyalakan lewat launcher, lanjut ke langkah praktik tanpa mengulang Start.

Bagian	Halaman
Alamat web, akun, dan peta demo	2
S1 SQL injection / S2 IDOR	3 / 4
S3 Hak akun / S4 Sumber koneksi / S5 Password lama	5 / 6 / 7
Retest otomatis dan cara membaca bukti	8
Kendala umum dan cara menghentikan lab	9

Lingkungan latihan

Semua langkah ditujukan hanya untuk lab lokal ini dengan data sintetis. S3-S5 memakai kredensial lab yang sudah disediakan. Jalankan pengujian **berurutan**; tunggu satu perintah selesai sebelum memulai berikutnya.

Kenali web dan data lab

Buka ketiga versi dengan hostname yang sama: selalu gunakan localhost.

Versi	Alamat dan fungsi
Rentan	http://localhost:8081 Baseline untuk membuktikan celah.
Query-fixed	http://localhost:8082 Pencarian diperbaiki; detail lintas pelanggan masih terbuka.
Hardened	http://localhost:8083 Binding, cek pemilik, akun terbatas, TLS database, error umum.

Akun latihan

Username	Password lab	Invoice yang menjadi haknya
alice	Lab-A-2026!	Pelanggan A: INV-001 dan INV-003
bob	Lab-B-2026!	Pelanggan B: INV-002

Login Alice pada tiap versi. Untuk menunjukkan Bob bersamaan pada versi yang sama, gunakan profil browser atau jendela incognito lain. Bisa juga logout Alice, lalu login Bob.

Urutan demo dan slide terkait

Skenario	Jalur	Slide
S1 - SQL injection pada pencarian	Browser	21
S2 - Alice meminta invoice Bob (IDOR)	Browser	22
S3 - Membandingkan hak akun database	PowerShell	23, 32
S4 - Password valid dari sumber terlarang	PowerShell	33
S5 - Password lama dipakai setelah rotasi	PowerShell	34

Kondisi pembandingan

Pencarian kosong sebagai Alice harus menampilkan **INV-001 dan INV-003**. INV-003 berdeskripsi **O'Reilly training**. INV-002 adalah milik Bob. Data dan pengguna yang sama membantu kita membaca perbedaan antarversi.

S1 / SQL injection

Browser | Slide 21 | Menguji apakah input pencarian dapat mengubah query

Tujuan: membuktikan bahwa input pada versi rentan dapat membuat invoice pelanggan lain ikut tampil, lalu membandingkannya dengan query yang memakai parameter binding.

Langkah praktik

1. Buka **http://localhost:8081**. Login **alice** dengan password **Lab-A-2026!**.
2. Kosongkan kolom pencarian lalu jalankan pencarian. Pastikan hanya **INV-001** dan **INV-003** yang muncul.
3. Tempel input berikut ke **kolom pencarian web**, kemudian jalankan pencarian:

```
' OR '1'='1' --
```

Gunakan tanda petik lurus ASCII. **Tambahkan satu spasi setelah dua tanda minus** jika spasi terakhir hilang saat menyalin dari PDF. Ini input web, bukan perintah PowerShell.

4. Periksa apakah muncul tiga invoice, termasuk **INV-002 milik Bob**. Identitas login tetap Alice.
5. Login Alice pada **8082**, lalu **8083**. Ulangi input yang sama di masing-masing versi.
6. Pada 8082 dan 8083, cari **O'Reilly**: INV-003 harus muncul. Kosongkan pencarian lagi: dua invoice Alice harus tetap tersedia.

Hasil yang diharapkan

Pengujian	8081	8082 / 8083
Input SQL injection	3 invoice, termasuk Bob	0 invoice
Pencarian kosong sebagai Alice	2 invoice Alice	2 invoice Alice
Pencarian O'Reilly	Error pada baseline	INV-003

Cara membaca hasil

Binding membuat input diproses sebagai **nilai pencarian**. Daftar kosong untuk payload harus disertai bukti bahwa pencarian normal masih bekerja. Hasil kosong saja belum cukup untuk menyatakan perbaikannya benar.

Bukti otomatis: jalankan Attacks (halaman 8), lalu lihat skenario S1 di lab/evidence/attacks.json.

S2 / IDOR

Browser | Slide 22 | Menguji akses ke invoice milik pengguna lain

Tujuan: memastikan pengguna yang sudah login tetap tidak dapat membaca objek milik pelanggan lain. Skenario ini tidak memerlukan payload SQL.

Langkah praktik

1. Login sebagai **Alice** pada **http://localhost:8081**.
2. Pada kolom **detail invoice**, masukkan **INV-002**, lalu jalankan permintaan detail. Invoice ini milik Bob, pelanggan B.
3. Amati bahwa detail milik B terbuka pada versi rentan. Ulangi sebagai Alice di **8082**: akses yang sama masih terbuka.
4. Ulangi di **8083**. Detail INV-002 harus ditolak dengan **HTTP 404**.
5. Masih sebagai Alice di 8083, minta **INV-001**. Invoice milik sendiri harus tetap terbuka dengan **HTTP 200**.
6. Sebagai perbandingan tambahan, logout lalu login Bob, atau gunakan sesi browser terpisah. Bob harus bisa membuka INV-002 miliknya di 8083.

Hasil yang diharapkan

Permintaan Alice	8081	8082	8083
INV-002 milik Bob	200, terbuka	200, terbuka	404, ditolak
INV-001 milik Alice	200	200	200

Jika status HTTP tidak terlihat di halaman, buka Developer Tools browser, pilih tab **Network**, ulangi permintaan detail, lalu periksa status request ke **/api/invoices/INV-002**.

Mengapa 8082 masih rentan?

Query detail sudah memakai parameter, tetapi pada dua versi awal belum ada pemeriksaan pemilik. Binding menutup masalah injection; **otorisasi objek** tetap harus ditambahkan. Pada hardened, nomor invoice dan identitas pelanggan dari sesi diperiksa bersama.

Bukti otomatis: skenario S2 di lab/evidence/attacks.json. HTTP 404 saja perlu dibaca bersama kontrol positif: invoice milik sendiri tetap 200.

S3 / Hak akun database

PowerShell | Slide 23 dan 32 | Membandingkan akun admin dengan akun runtime

Tujuan: melihat dampak hak database yang terlalu luas. Akun sudah disediakan oleh lab; ini bukan proses mencuri kredensial atau menaikkan hak akun.

Langkah praktik

1. Pastikan lab berjalan. Buka PowerShell pada folder **lab**, seperti dijelaskan di halaman 1.
2. Jalankan satu baris perintah berikut dan tunggu sampai selesai:

```
docker compose --profile tools run --rm tester python tests/attacks.py --scenario S3
```

3. Periksa keluaran **PASS S3**. Buka file hasil individual dengan perintah:

```
Get-Content .\evidence\attack-S3.json
```

Yang dilakukan runner dan hasilnya

Percobaan	Hasil yang diharapkan
lab_admin membaca internal.audit_sentinel	Berhasil; satu baris internal.
lab_admin mengubah status INV-002	Berhasil sementara menjadi Demo-only; lalu ROLLBACK dan status awal dipastikan kembali.
app_runtime membaca tabel internal	Ditolak: SQLSTATE 42501.
app_runtime melakukan UPDATE	Ditolak: SQLSTATE 42501.
app_runtime SELECT tabel invoice	Berhasil; tiga baris sebagai kontrol positif.

Di JSON, periksa **passed**, **runtime_denials**, **invoice_state_restored**, dan **authorized_select_rows**. Nilai terakhir diharapkan 3; pemulihan status diharapkan true.

Batas kesimpulan

UPDATE dilakukan langsung melalui koneksi database, bukan melalui web. Web lab memakai transaksi read-only. Akun runtime tetap bisa membaca seluruh tabel invoice yang diberi SELECT; pemisahan Alice dan Bob dilakukan aplikasi. **RLS belum diterapkan.**

File individual tidak memperbarui ringkasan attacks.json. Jalankan Attacks setelah demo individual untuk membuat laporan lengkap yang konsisten.

S4 / Sumber koneksi terlarang

PowerShell | Slide 33 | Password benar, tetapi sumber tidak diizinkan

Tujuan: membuktikan aturan sumber koneksi PostgreSQL menolak klien tertentu meskipun password runtime yang dipakai valid.

Langkah praktik

1. Pastikan S3 sudah berhasil agar ada pembandingan: tester dari **172.30.26.40** dapat terhubung dan melakukan SELECT.
2. Dari PowerShell pada folder **lab**, jalankan:

```
docker compose --profile tools run --rm untrusted
```

3. Tunggu hingga selesai. Periksa alasan penolakannya: aturan **pg_hba.conf** menolak klien **172.30.26.30**.
4. Buka bukti koneksi dengan perintah:

```
Get-Content .\evidence\network.json
```

5. Cocokkan sumber dan hasil aktual. Jangan menganggap timeout atau password salah sebagai bukti bahwa aturan HBA bekerja.

Pembandingan yang harus ada

Sumber	Kredensial	Hasil
Tester .40	Akun runtime valid	Bisa konek dan SELECT (S3).
Untrusted .30	Akun runtime valid	Ditolak oleh PostgreSQL melalui HBA.

Penolakan yang benar

Klien .30 mencapai PostgreSQL, lalu ditolak oleh aturan koneksi. Ini **bukan penolakan firewall**. Runner memakai TLS verify-full; aturan HBA tidak diubah atau dilonggarkan selama perbandingan.

Jika .40 dan .30 sama-sama gagal, periksa kesehatan layanan dan konfigurasi terlebih dahulu. Jika pihak yang menyalahgunakan akun berada di sumber yang diizinkan, pembatasan ini saja tidak menghentikannya; hak akun tetap perlu dibatasi.

Untuk bukti S1-S5 dengan run ID yang sama, jalankan Attacks pada halaman 8. network.json hasil demo individual dapat memiliki run ID berbeda dari ringkasan lama.

S5 / Password lama setelah rotasi

PowerShell | Slide 34 | Menguji koneksi baru sebelum dan setelah password diganti

Tujuan: membuktikan password lama tidak lagi diterima untuk koneksi baru setelah rotasi, sementara password saat ini dan aplikasi tetap bekerja.

Langkah praktik

1. Pastikan tidak ada proses **Test**, **Attacks**, atau S5 lain yang sedang berjalan. Tunggu pengujian sebelumnya selesai.

2. Dari PowerShell pada folder **lab**, jalankan:

```
docker compose --profile tools run --rm tester python tests/attacks.py --scenario S5
```

3. Biarkan proses selesai; jangan menutup terminal di tengah rotasi. Periksa keluaran **PASS S5**.

4. Buka bukti individual dengan perintah:

```
Get-Content .\evidence\attack-S5.json
```

Urutan otomatis di dalam runner

Tahap	Hasil yang diharapkan
1. Tetapkan password lama untuk baseline	Koneksi baru dengan password lama berhasil.
2. Ganti ke password saat ini	Password lama ditolak untuk koneksi baru; alasannya kegagalan autentikasi.
3. Coba password saat ini	Koneksi baru berhasil.
4. Periksa aplikasi hardened	Permintaan aplikasi berhasil, HTTP 200.

Di JSON, cocokkan **before_rotation**, **after_rotation**, **current_password**, dan **application_http**. Runner membaca secret lab sendiri; tidak perlu menyalin atau menampilkan nilai secret.

Batas penting

Rotasi ini menguji **koneksi baru**. Sesi database yang sudah tersambung tidak otomatis terputus. Blok finally mengembalikan password saat ini ketika proses selesai atau mengalami kegagalan biasa; jangan mengandalkannya saat proses dihentikan paksa.

Jalankan Attacks sesudah demo individual jika membutuhkan ringkasan kelima skenario dalam satu rangkaian.

Retest dan bukti lengkap

PowerShell | Slide 38 dan 41 | Jalankan semua skenario secara otomatis

Jalankan kelima skenario

```
.\lab.ps1 Attacks
```

Tunggu sampai selesai. Skrip menjalankan S1, S2, S3, S5 dari tester, lalu S4 dari untrusted, kemudian menyatukan laporan. Target keluaran akhirnya:

```
FIVE SCENARIOS: 5/5
```

Perintah harus selesai tanpa error dan dengan exit code 0. Buka laporan:

```
Get-Content .\evidence\attacks.json
```

Bagian laporan	Yang diperiksa
timestamp dan run_id	Waktu sesuai run terbaru; hasil inti dan sumber terlarang berasal dari rangkaian yang sama.
passed dan total	Target passed = 5 dan total = 5.
scenarios	Ada S1 sampai S5; periksa passed dan actual pada setiap skenario.

PASS berarti sesuai ekspektasi

Pada baseline rentan, PASS dapat berarti celah sengaja berhasil direproduksi. Pada hardened, PASS berarti pembatasan yang diuji bekerja. **PASS bukan klaim seluruh sistem aman.** Jika proses gagal sebelum agregasi, attacks.json lama mungkin masih ada. Selalu cek waktu dan run ID.

Pemeriksaan pendukung, jalankan terpisah

```
.\lab.ps1 Test
```

Suite ini memeriksa 51 kondisi aplikasi, privilege, TLS, log, rotasi, dan sumber koneksi, lalu backup/restore serta 4 kondisi aplikasi hasil restore. Jalankan berurutan dengan Attacks, jangan bersamaan.

Bukti pendukung: lab/evidence/retest.json, network.json, restore.json, dan restore-app.json.

TLS, error/log, dan restore adalah pengujian pendukung di luar lima skenario. Restore dilakukan ke database lain pada cluster lab yang sama, bukan uji pemulihan seluruh infrastruktur.

Kalau hasilnya berbeda

Periksa penyebabnya sebelum mengulang atau menyimpulkan pengamanan gagal.

Gejala	Langkah pemeriksaan
Web tidak bisa dibuka	Pastikan launcher/Start sudah selesai. Jalankan Status di bawah. Tunggu Docker Desktop siap dalam mode Linux containers.
Port 8081-8083 sudah dipakai	Hentikan layanan lain yang memang Anda kenali, atau sesuaikan port host di compose.yaml dan URL yang dipakai.
S1 tidak sesuai tabel	Pastikan sedang login Alice dan membuka port yang benar. Gunakan petik lurus serta spasi setelah --. Ulangi pencarian kosong sebagai pembanding.
S2 di hardened masih terbuka	Pastikan akun aktif benar-benar Alice, nomor INV-002, dan URL memakai 8083. Jangan tertukar sesi Bob atau versi query-fixed.
S4 gagal dengan timeout/password salah	Itu belum membuktikan HBA. Periksa koneksi tester .40, kesehatan DB, dan konfigurasi sumber. Jangan melonggarkan aturan hanya agar demo berjalan.
S5 atau tes lain terganggu	Pastikan tidak berjalan bersamaan. Jangan menghentikan rotasi di tengah proses. Jangan menghapus runtime atau volume database untuk mencoba reset.
Laporan masih menunjukkan hasil lama	Cek timestamp. Setelah demo individual, jalankan Attacks hingga agregasi selesai agar attacks.json diperbarui.

Periksa status atau hentikan lab

```
.\lab.ps1 Status
.\lab.ps1 Stop
```

Status hanya memeriksa layanan. **Stop** menghentikan layanan dan mempertahankan volume data serta konfigurasi. Jalankan Start lagi untuk memakai lab yang sama.

Jika PowerShell memblokir skrip, ikuti alternatif Docker Compose pada lab/README.md sesuai kebijakan perangkat. Jangan menghapus hanya lab/runtime atau hanya volume database; keduanya perlu tetap sinkron.

Saat webinar dan rujukan lokal

Jika demo terganggu, gunakan screenshot aktual dan laporan di **lab/evidence/**. Sebutkan bahwa itu hasil run sebelumnya. Gambar slide bukan bukti eksekusi langsung.

Panduan ini mengikuti lab/ATTACKS.md, lab/DEMO.md, lab/README.md, lab/lab.ps1, dan lab/tests/attacks.py pada paket kegiatan 26 September 2026. Langkah disusun dari kode dan panduan paket; angka di dokumen adalah target pengujian, bukan klaim bahwa lab baru dijalankan pada saat PDF dibuat.